

EUROPEAN SPACE AGENCY

PERSONAL DATA PROTECTION FRAMEWORK

- I. The Principles of Personal Data Protection
adopted by ESA Council on 13 June 2017
- II. The Rules of Procedure for the Data Protection Supervisory Authority
adopted by ESA Council on 13 June 2017
- III. The Policy on Personal Data Protection (including its Annex “Governance Scheme
of the Agency’s Personal Data Protection”)
adopted by Director General of ESA on 1 March 2022

I. PRINCIPLES OF PERSONAL DATA PROTECTION

(adopted by ESA Council on 13 June 2017)

The main principle is the protection by the Agency of personal data and data subjects, in particular staff members and contractor personnel, with regard to the processing of personal data. Subsequent Policy and rules shall set forth the specific framework on:

1. Personal Data quality

The Policy shall provide data quality conditions, including on accuracy and update of personal data. It shall also set the conditions related to the erasure, rectification, completion and amendment of personal data.

2. Processing of Personal Data

The Policy shall detail the conditions of processing of Personal Data (e.g. collection, recording, disclosure, deletion, etc.) for fair, specified and legitimate purposes, in not excessive manners and in conditions protecting confidentiality, integrity and security of personal data.

The Policy shall detail the conditions for processing to be deemed fair and legitimate, in particular when it relates to the security and the performance of an activity carried out by the Agency in conformity with the ESA Convention, the *“Agreement between the States Parties to the Convention for the establishment of a European Space Agency and the European Space Agency for the protection and the exchange of classified information”* done in Paris on 19 August 2002, and the applicable rules and procedures.

For those personal data which are sensitive data (e.g. personal data revealing racial or ethnic origins, political opinions, religious or philosophical beliefs, health data, criminal convictions of a data subject), the Policy shall provide the exceptional cases in which processing is permitted.

3. Disclosure of Personal Data

The Policy shall, in compliance with the general conditions set forth in Article 2 above, identify specific principles on disclosure (or “transfer”) of personal data within the Agency and outside the Agency:

- to enable free disclosure within the Agency,
- to permit disclosure to an international organization in charge of the management of the Agency’s Pension Scheme,
- to set the conditions for disclosure of personal data to recipients located outside the Agency, depending on whether the country or the international organisation provides or not an adequate level of protection for the personal data,
- to set the conditions of recognition of the adequate level of protection or of its suspension or withdrawal.

4. Data subjects' rights

The following rights of the Data Subjects shall be recognized, protected and exercised in conditions to be set in the Policy:

- the right to be informed in particular about the identity of the data controller, the contact details of the data protection officer, the purpose of the data processing, the data recipients to whom the personal data shall be disclosed, the rights of rectification or erasure of his/her data, the storage time-limits (if any), the practical modalities of exercising the rights, etc.
- the right for every data subject to access the personal data relating to him/her,
- the right for every data subject to have his/her personal data erased, rectified, completed,
- the right for every interested data subject to lodge a complaint in accordance with the Rules of Procedure of the Supervisory Authority, in case he/she demonstrates or has serious reasons to believe that a data protection incident occurred in relation with his/her personal data, following a decision of the Agency.

5. Personal Data security

The Policy shall require that appropriate measures must be taken against the risks of loss as well as against unauthorised access, destruction, use, modification or disclosure of personal data, in particular when such risks concern sensitive personal data.

In case of disclosure of personal data to one of its contractors, the Agency shall require any such contractor to assume obligations consistent with the terms of the Policy and of any security procedures adopted in the implementation of the Policy.

6. Principles concerning prevention, reporting and investigation of Data Protection Incidents

To ensure effective protection of personal data and for the prevention and resolution of data protection incidents, the Policy shall require that the Agency shall:

- i. assign clear roles and responsibilities within the Agency in relation with Personal Data protection matters,
- ii. adopt, enhance and implement prevention and emergency measures,
- iii. put in place control and audit,
- iv. investigate, mitigate the consequences of and, to the extent possible, remedy the reported or detected data protection incidents.

7. Processing of personal data on behalf of the Agency

The Agency shall assign the responsibility of processing of personal data to a third party data processor only if the latter provides adequate warranties of compliance with the level of protection of the personal data set forth by the Policy as well as in the applicable procedures, and takes commitments consistent therewith.

II. RULES OF PROCEDURE FOR THE DATA PROTECTION SUPERVISORY AUTHORITY

(adopted by ESA Council on 13 June 2017)

These rules determine the procedure for the Data Protection Supervisory Authority (“Supervisory Authority”). The Supervisory Authority shall be completely independent in its proceedings including deliberations and decisions; its work shall not be disclosed, except for the decisions which shall be communicated as per Article 12 herein.

1. Complainant

Every interested data subject (“complainant”) has the right to lodge a complaint in accordance with these Rules of Procedure in case he/she demonstrates or has serious reasons to believe that a data protection incident occurred in relation with his/her personal data, following a decision of the Agency.

2. Preliminary complaint and amicable resolution effort

Before filing a complaint with the Supervisory Authority, the complainant shall:

- inform the Agency’s function or body whose decision is concerned about her/his intention to file a complaint with the Supervisory Authority and the ground for such complaint; and
- reasonably seek for an amicable resolution of the case.

3. Complaint with the Supervisory Authority

In case the complainant and the Agency have not reached an amicable resolution of the case in a reasonable time (not exceeding two months), the complainant shall lodge his/her complaint as follows:

- with the Registrar of the Supervisory Authority;
- no later than three months after the date of receipt of the decision which is challenged;
- dated and signed by the complainant;
- identifying the decision challenged and, if possible, containing a copy thereof;
- including a summary of the grounds and the relief claimed, together with any documentary evidence;
- in the English or French language.

Registration of a complaint against a decision of the Agency shall not suspend its execution.

4. Registrar's responsibilities

The Registrar of the Supervisory Authority shall:

- register the complaint and any evidence, comment, reply or other document communicated to the Supervisory Authority in relation with the complaint;
- be responsible for the communication of documents to the parties;
- communicate the date of the hearings (if any) to the members of the Supervisory Authority and the parties at least fifteen (15) working days beforehand;
- be in charge of all communications and notifications to the parties;
- be present at all hearings (if any), at the request of the Supervisory Authority.

5. Comments to complaint and reply

The complaint shall be transmitted by Registrar of the Supervisory Authority to the Agency through the Data Protection Officer and the Head of the service in charge of Compliance.

The Agency shall notify to the Supervisory Authority its comments, in writing and within thirty (30) working days from the communication of the complaint.

These comments shall be conveyed by Registrar of the Supervisory Authority to the claimant, who shall have thirty (30) working days to present a written reply.

These timeframes may be extended by the Chairman of the Supervisory Authority.

6. Pre-judicial decisions of the Supervisory Authority

Where necessary, the Supervisory Authority shall, before examining the complaint submitted to it, rule on any objections concerning its own composition.

The members of the Supervisory Authority shall not take part in a case in which they have a conflict of interest, notably if they have a personal interest in the case, if they have been previously involved as representative of one of the parties, or if they participated in preparing the decision challenged. In such case, either party may ask for a change in the composition of the Supervisory Authority.

The Supervisory Authority shall rule, at any time it deems appropriate, on any challenge to its jurisdiction, and on any difficulties occasioned by the application of these rules of procedure.

Where necessary, the Supervisory Authority shall, before examining the complaint submitted to it, rule on interim measures that may be necessary to be taken until the Supervisory Authority issues its final decision.

7. Representation and assistance

The Parties may be represented or assisted by persons (e.g. lawyers, advisors, etc.) of their choice. The Supervisory Authority may invite the complainant to appear before it in person.

8. Written procedure

The Supervisory Authority may decide to proceed with a written procedure or to call for a hearing.

9. Hearing

In case the Supervisory Authority calls for a hearing, the hearings shall be conducted under the authority of the Chairman of the Supervisory Authority or his/her deputy.

The hearings shall be public, unless the Supervisory Authority *ex officio* or at the request of one of the parties shall, for valid reasons, decide otherwise.

The language of the hearings shall be either English or French.

The Supervisory Authority may decide to examine a case in the absence of one or both of the parties, provided that the date of the hearing has been duly notified to the parties concerned.

If one or both of the parties, although duly summoned, fails or fail to appear before the Supervisory Authority, without producing a valid reason, the Supervisory Authority may close the hearings and make its final decision.

Any person having attended a hearing of the Supervisory Authority held *in camera* shall observe the strictest secrecy concerning any facts that may have come to his/her knowledge in the course of the proceedings and any opinions expressed thereat.

10. Establishment of facts

The Supervisory Authority may at any time:

- request from either party any information which it deems necessary and appropriate for the examination of the case;
- call a witness, upon its own initiative or upon proposal of a party.

A witness shall not be bound to disclose information to the Supervisory Authority if he/she has professional or moral objections which are acceptable to the Supervisory Authority in accordance with the general principles of law.

11. Withdrawal of the complaint

Should the claimant withdraw his/her complaint, the Chairman of the Supervisory Authority may accept it after consultation of the other party.

12. Deliberation and decisions

After closure of the written procedure or, as the case may be, of the hearing, the Supervisory Authority shall deliberate on its decision.

The deliberations of the Supervisory Authority shall be held out of the presence of either party or of any other person.

Before issuing a decision, the Supervisory Authority may propose to parties amicable resolution or settlement.

The decisions of the Supervisory Authority shall:

- be taken by majority;
- state the grounds on which the Supervisory Authority's decisions are based;
- contain findings which cover the main facts and legal arguments put forward by the two parties;
- state the names of the members of the Supervisory Authority who took part in the deliberations;
- be signed by the chairman of the Supervisory Authority and the registrar;
- indicate the date of the decision;
- be sent to the Director General, the Data Protection Officer and to the complainant, in copies certified true by the registrar, within thirty days of being delivered or, where this time limit of thirty days cannot be respected, in the timeframe authorised by the chairman;
- may also be communicated to any person upon request, unless otherwise the Supervisory Authority so decides; the Supervisory Authority may decide that a decision shall only be communicated with the name of the claimant or any other person mentioned therein deleted.

The Supervisory Authority may award financial compensation to the claimant within the limit of 10,000 Euro.

The decisions of the Supervisory Authority shall be final and binding on both parties; no appeal is possible against them.

13. Costs

The proceedings before the Supervisory Authority shall be free of charge. The Agency shall in all cases pay its own costs.

Any costs incurred by the claimant in the course of the proceedings, in particular fees payable to a person chosen from outside the Agency to represent or assist him/her, shall be borne by him/her, unless the Supervisory Authority decides otherwise.

14. Review

The Supervisory Authority may be asked by the parties to:

- interpret a decision, should difficulties arise as to the meaning or scope of the decision;
- review a decision if a fact of decisive importance comes to the knowledge of the Supervisory Authority and of one of the parties after the pronouncement of such a decision; nevertheless, no request for review may be made after the expiry of a period of three months following the discovery of the fact mentioned above and - in any case - five years after the date of the decision. The period of three months shall not apply if the claimant was unable for valid reasons to make the request.

Any request for interpretation or review shall be submitted to the chairman of the Supervisory authority who may deliver a reasoned decision stating the request to be inadmissible, if (i) he/her considers that this request clearly amounts to an appeal against a decision of the Supervisory Authority and (ii) none of the members of the Supervisory Authority who would be called upon to deal with the matter objects in writing. There shall be no appeal against this decision.

Subject to the above provision, the procedure for review shall commence with a decision of the Supervisory Authority formally declaring that a new fact exists, that it is of a character which justifies the review, and that the request for review is admissible for that reason.

Clerical and arithmetical mistakes in the decision, or any accidental error or omission, may be corrected by the Supervisory Authority, either on its own initiative or on the application of either party.

III. POLICY ON PERSONAL DATA PROTECTION

(adopted by Director General of ESA on 1 March 2022)

1. INTRODUCTION

In the performance of its mission, the Agency collects and Processes certain Personal Data concerning various individuals, in particular Staff Members or Contractor Personnel. These Personal Data may be collected by the Agency or made available to the Agency by the individuals themselves or by third parties, located in several jurisdictions.

The Agency, while not being subject to national or international laws on Personal Data protection, wants to ensure a high level of protection of Personal Data and, by doing so, to preserve the dignity and privacy of the concerned individuals.

To that effect, Council adopted, on 13 June 2017, the Resolution on a “Personal Data Protection Policy” (ESA/C/CCLXVIII/Res.2 (Final)) setting forth the principles of Personal Data Protection at ESA and mandating the Director General to adopt a Policy on Personal Data Protection (“Policy”) implementing the said principles and establishing an appropriate governance scheme, the latter to be composed of an independent Data Protection Supervisory Authority, an internal Data Protection Committee, and a Data Protection Officer.

2. POLICY

In order to ensure a high level of protection of Personal Data concerning individuals and in particular Agency’s Staff Members and Contractor Personnel, it is the Agency’s policy to:

- adopt a structured framework to effectively ensure the protection and safeguard of Personal Data Processed or disclosed by, on behalf of, or to the Agency;
- increase awareness and responsibility of Staff Members with respect to Personal Data protection;
- establish governance, including functions and bodies (e.g. Data Protection Officer, Data Protection Supervisory Authority, Data Protection Committee) and operations necessary for the effectiveness of Personal Data protection.

3. DEFINITIONS

For the purpose of this Policy and its Annex, the following terms are defined as follows:

Adequate Level of Protection means a level of protection of Personal Data adequate in the consideration of this Policy, as recognised:

- (i) by decision(s) taken by the Director General upon recommendation of the Data Protection Officer;
- (ii) by this Policy to the following countries and international organisations:
 - a. the Member States of the Agency, the European Union, its institutions and bodies as well as the States which are members of the European Union; and

- b. the countries and other international organisations recognised by the European Commission as offering an adequate level of protection under the European Union's legal framework.

Consent means any freely given, specific, informed and unambiguous permission expressed by a Data Subject relating to the Processing of his/her Personal Data.

Contractor means the natural or legal person who has entered into a Contract with the Agency and who, with regard to Personal Data, acts either as a Data Controller or as a Data Processor.

Contractor Personnel means the personnel engaged by the Contractor (including that of its subcontractors) to undertake the contracted tasks and who is acting under the Contractor's responsibility.

Data Controller means any natural or legal person who makes the decision, determining the purposes and means, alone or conjointly, to Process Personal Data, or commissions others to Process Personal Data on its behalf. The quality of Data Controller belongs to the Agency itself, not to the Agency's Staff Member who is materially involved in the related activities. The quality of Data Controller belongs to the Contractor itself, not to the Contractor Personnel who is materially involved in the related activities.

Data Processor means any natural or legal person, who Processes Personal Data on behalf of the Data Controller. With regard to Personal Data Processing materially operated by a Staff Member, the quality of Data Processor belongs to the Agency itself, not to the Staff Member. The quality of Data Processor belongs to the Contractor itself, not to the Contractor Personnel who is materially involved in the related activities.

Data Protection Officer means the Agency's Staff Member appointed by the Director General to perform the duties listed in Annex to this Policy or assigned to him/her by decision of the Director General.

Data Protection Committee means the consultative body established under the Annex to this Policy.

Data Protection Supervisory Authority or Supervisory Authority means the independent supervisory authority in the field of Personal Data protection, as established by Council.

Data Subject means an individual who is the subject of Personal Data.

Disclosure (or "transfer") of Personal Data or Disclosure (or Disclose) means the process of making Personal Data available to individuals, entities, or processes, including by rendering remotely accessible Personal Data.

Dispute Resolution Procedure means a process for resolving, internally or externally, differences or conflict between two or more parties, such as a litigation, arbitration, mediation or conciliation procedure.

Health-related Sensitive Personal Data means Personal Data relating to the physical or mental health of the Data Subject.

Incident or Data Protection Incident means any intentional or unintentional activity which violates the provisions set forth in this Policy.

Investigation Procedure means a process of examination or search, whether internal or external to the Agency, in order to gather facts and collect evidence.

Personal Data means any information concerning an identified or identifiable Data Subject, in this latter case provided that identification of the said Data Subject may be done without unreasonable efforts directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that Data Subject.

Personal Data Processing or Processing (or Process) means any operation or set of operations performed on Personal Data or sets of Personal Data, whether or not by automated means, such as collection, recording, organisation, structuring, storage, adaptation or alteration, retrieval, consultation, use, Disclosure by transmission, dissemination or otherwise making available, alignment or combination, restriction, erasure or destruction.

Personal Data Recipient or Recipient means, in relation to a Disclosure of Personal Data, a third party (e.g. a natural or legal person, including another Data Controller or Data Processor, but which is not acting under the authority of the said third party), to which Personal Data is disclosed.

Personal Data Records means, in relation to Personal Data, records to be created and maintained by the Data Protection Officer, including concerning Personal Data Processing, requests made by Data Subjects in the exercise of their rights under this Policy, notifications, investigations, recommendations and findings related to Data Protection Incidents.

Sensitive Personal Data means Personal Data that can reveal without unreasonable efforts the racial or ethnic origins, political opinions, trade union membership, religious or philosophical beliefs, health or sexual life, genetic or biometric data, or criminal convictions of a Data Subject.

4. SCOPE

This Policy protects all Personal Data, relating to any Data Subject, whether collected by the Agency or disclosed to the Agency by a third party.

For the sake of clarity, this Policy does not apply to data that are rendered anonymous in such an irreversible way that Data Subjects cannot be readily identified from the data.

The specific provisions set forth in this Policy are without prejudice to the security principles and the security implementation standards, which are laid down in the ESA Security Regulations and Directives.

5. PRINCIPLES

The following principles concerning

- i. Personal Data quality,
- ii. Processing of Personal Data and Sensitive Personal Data,
- iii. Disclosure of Personal Data,

- iv. Data Subject's rights,
- v. Personal Data protection,
- vi. Prevention, reporting and investigation of Data Protection Incidents, and
- vii. Processing of Personal Data on behalf of the Agency

are common to all Data Subjects and shall be implemented according to the applicable Agency's procedures and guidelines.

5.1 Personal Data quality

Personal Data shall be:

- i. accurate and, where necessary, kept up to date.

To that effect, at the request of a Data Subject, Personal Data may be rectified, completed, amended, as the case may be, to the extent the data is shown to be inaccurate or incomplete, having regard to the purposes for which they are Processed.

Additionally, Personal Data may be erased following a request by a Data Subject, to the extent that:

- a. the Personal Data are no longer necessary in relation to the purposes for which they were Processed; or
- b. the Data Subject withdraws its Consent on which the Processing is based according to Sections 5.2 and 5.3, and there is no other legal ground for the Processing; or
- c. the Personal Data are Processed in violation with the principles referred to in Section 5.2. of this Policy.

The Data Controller shall take reasonable steps to accommodate such requests by, *inter alia*, taking into account available technology and the resources related to implementation.

- ii. kept in a form which permits identification of the Data Subject as necessary for the purposes for which the Personal Data were collected or for which they are further Processed.

5.2 Processing of Personal Data and Sensitive Personal Data

5.2.1 General.

Processing of Personal Data shall be done:

- i. fairly, for specified and legitimate purposes and may be further processed in a way compatible with those purposes, the compatibility being assessed by the Data Protection Officer; the foregoing conditions shall be verified taking into account, cumulatively, the circumstances under which the Personal Data are Processed, the purposes that a reasonable Data Subject would consider appropriate, the necessity of the Processing, and the duration of the associated retention.

The Processing is deemed fair and legitimate when it relates to:

- a. the performance of an activity carried out by the Agency within its purpose and in the framework of, and in conformity with, the ESA Convention, the

“Agreement between the States Parties to the Convention for the establishment of a European Space Agency and the European Space Agency for the protection and the exchange of classified information” done in Paris on 19 August 2002, and the applicable rules and procedures, including ESA Security Regulations and Directives; this includes Processing necessary for the Agency’s management and functioning, Dispute Resolution Procedure, and or Investigation Procedures; or

- b. compliance with a legal obligation to which the Agency is subject; or
 - c. a task in the frame of the Agency’s cooperation with the competent authority of Member States, in order to facilitate the proper administration of justice; or
 - d. security; or
 - e. the performance of a contract concluded by the Agency within its purpose in relation with an activity carried out by the Agency in the framework of, and in conformity with, the ESA Convention and the applicable rules and procedures; or
 - f. the legitimate interest of the Data Subject; or
 - g. a purpose covered by the Consent of the Data Subject.
- ii. in a not excessive manner, as necessary for the purposes for which the Personal Data were collected or for which they are further Processed; and
 - iii. in conditions protecting the confidentiality, integrity and protection of Personal Data, preserving the rights of the Data Subject set forth in Section 5.4 herein, and conforming to instructions from the Data Controller.

When designing and selecting information technology systems, software and services for the Processing of Personal Data, compliance with the principles set forth in this Policy shall be ensured, throughout the data life cycle and data flow of the Processing operation.

When Processing Personal Data, the relevant organisational entity of the Agency shall initiate a risk assessment implementing the processes designed to comply with this Policy, as appropriate, and establish the relevant mitigation actions and risk management measures to address the identified risks by applying the principles established in the [Agency’s Risk Management Policy](#) (ESA/ADMIN/IPOL-RISK(2018)01).

Specifically, prior to a Processing of Personal Data likely to result in a high risk to the Data Subject rights, in particular with regard to the use of new technologies, social media systems and other similar technologies, an appropriate risk assessment shall be conducted and proactive risk mitigation measures identified in order to ensure protection in accordance with this Policy.

With regard to Processing of Personal Data for scientific or historical research purposes or archiving purposes, the Director General may decide, upon recommendation of the Data Protection Officer, on derogations from the principles set forth in Sections 5.1 and 5.4, subject to appropriate safeguards, in so far as such rights are likely to impair the achievement of such specific purposes, and such derogations are necessary for the fulfilment of those purposes.

5.2.2. Sensitive Personal Data.

5.2.2.1 The Processing of Sensitive Personal Data is forbidden, except if:

- i. it is covered by the Consent of the Data Subject; or
- ii. it relates to Sensitive Personal Data which are manifestly made public by any means (for instance, social media) by the Data Subject; or
- iii. it is necessary for:
 - a. the protection of the vital interests of the Data Subject or of another natural person where the Data Subject is physically or legally incapable of giving Consent; or
 - b. Dispute Resolution and Investigation Procedures; or
 - c. the purposes of carrying out obligations of the Agency under the applicable Staff Regulations, Rules and Instructions or Pension Rules or the provision of health or social care or the treatment or the management of health or social care systems and services; and
 - d. the protection against serious threats to security or individual or public health.

5.2.2.2 In all these cases, Processing must be done in accordance with the principles set forth in Section 5.2.1, and with the provisions on the protection of information described in the ESA Security Directives, and the Data Protection Officer shall be notified prior to such Processing.

5.2.2.3 In addition, the Processing of Health-related Sensitive Personal Data may only be done:

- a. by, or under the responsibility of, a health professional subject to the obligation of professional secrecy or an Agency Staff Member managing health care or social security services or a Contractor acting on behalf of the Agency in the field of social security; and
- b. under the generally applicable medical professional standards, as recommended by the Agency's medical advisor.

5.3 Disclosure of Personal Data

In all cases mentioned below, Personal Data shall be Disclosed in compliance with the general Processing principles set forth in Section 5.2.

5.3.1. Disclosure within the Agency

- i. Disclosure within the Agency shall be done freely, in line with this Policy, regardless of the country where the Data Recipient within the Agency is located.
- ii. Disclosure of Personal Data to identified entities in charge of the management of the Agency's Pension Scheme within an international organisation, which is not subject to the national law of a Member State, shall be considered as a Disclosure within the Agency.

5.3.2. Disclosure outside the Agency

- i. The Data Protection Officer shall be notified prior to any Disclosure outside the Agency, according to the applicable Agency's procedures and guidelines.

- ii. Disclosure of Personal Data to Data Recipients located outside the Agency is authorised provided that the concerned country or the international organisation (others than the international organisations mentioned under Section 5.3.1 ii.) is recognised as providing an Adequate Level of Protection.

Such recognition may at any time be suspended or withdrawn by the Director General, upon recommendation of the Data Protection Officer in order to safeguard the Agency's interests or those of the Data Subjects.

- iii. Notwithstanding the above and without prejudice to the other provisions of this Policy, Personal Data can however be Disclosed to Data Recipients located in a country or international organisation not offering an Adequate Level of Protection, if one of the following occurs:
 - a. the concerned Data Subject has given his/her Consent to the proposed Disclosure; in case the Disclosure is related to the performance of an activity carried out by the Agency within its purpose and in the framework of, and in conformity with, the ESA Convention, one of the conditions in sections b – f must also occur;
 - b. the Disclosure is necessary for the performance of a contract between the Data Subject and the Data Controller or the implementation of pre-contractual measures taken in response to the Data Subject's request;
 - c. the Disclosure is necessary for the conclusion or the performance of a contract entered into in the interest of the Data Subject between the Agency and a third party;
 - d. the Disclosure is necessary or legally required on important grounds of public interest, or for any Investigation or Dispute Resolution Procedure;
 - e. the Disclosure is necessary in order to protect the vital interests of the Data Subject or that of the Agency; or
 - f. the Disclosure has been previously authorised by the Data Protection Officer under Section I vi. of the Annex following an impact assessment to be performed by the relevant organisational entity of the Agency and is done with the adequate safeguards with respect to the protection of the Personal Data and Data Subject's rights; such safeguards may in particular result from appropriate contractual clauses.

5.4 Data Subject's rights

5.4.1 The following rights of the Data Subjects, regardless of whether Personal Data have been obtained from the Data Subject, shall be recognised and protected by the Agency:

- i. The right to be informed, in a transparent manner, as reasonably practicable, about:
 - a. the identity of the Data Controller and the contact details of the Data Protection Officer;
 - b. the purpose of the Data Processing, in case his/her Personal Data are Processed;
 - c. the Data Recipients to whom his/her Personal Data shall be Disclosed;

- d. the existence of the rights mentioned in this Section 5.4.1 paragraphs ii., iii. and iv. below;
 - e. the time-limits for storing the Personal Data (or the criteria used to determine the time-limits) as decided, in compliance with Section 5.2, by the Director General upon proposal of the Data Protection Officer (following consultation of the Department in charge of personnel matters, the Record Manager and other relevant Departments); and
 - f. the practical modalities of exercising the rights set forth in this Section 5.4.1 paragraphs ii., iii. and iv.
- ii. The right for every Data Subject to make a reasonable request for access to the Personal Data relating to him/her; in addition, in the case of Health-related Sensitive Personal Data, the conditions under which access is granted are those corresponding to generally applicable medical professional standards, as recommended by the Agency's medical advisor;
- iii. The right for every Data Subject to have his/her Personal Data erased, rectified, completed, or amended as per the conditions set under Section 5.1. i. of this Policy;
- iv. The right for every interested Data Subject to lodge a complaint before the Supervisory Authority in case the former demonstrates or has serious reasons to believe that a Data Protection Incident occurred in relation with his/her Personal Data, following a decision of the Agency (e.g. Data Protection Officer). Such complaint shall be lodged in accordance with the Rules of Procedure of the Supervisory Authority.

5.4.2 The right of information under Section 5.4.1 i. and the right of access under Section 5.4.1 ii. shall not apply:

- a. where and insofar as the Data Subject is already in possession of the information;
- b. for the right of information, when processing of Personal Data is necessary for any Investigation or Dispute Resolution Procedure;
- c. for the right of access, where and insofar such access would conflict with an Investigation Procedure concerning the Data Subject.

5.5 Personal Data protection

The Agency shall take any appropriate measures against the risks of loss of Personal Data as well as against unauthorised access, destruction, use, modification or Disclosure of Personal Data, in particular for what concerns Sensitive Personal Data. Such appropriate measures and procedures for the protection of Personal Data are detailed in the ESA Security Directives, and are to be implemented under the supervision of the ESA Security Office.

In case of Disclosure of Personal Data to a Contractor, the Agency shall require the Contractor to assume obligations consistent with the terms set of this Policy and of any Personal Data protection procedures adopted in the implementation of this Policy.

5.6 Prevention, reporting and investigation of Data Protection Incidents

To ensure effective protection of Personal Data, a high priority is placed on prevention and resolution of Data Protection Incidents by:

- i. assigning clear roles and responsibilities within the Agency in relation with Personal Data protection matters;
- ii. adopting, enhancing and implementing prevention and emergency measures;
- iii. putting in place controls and audits; and
- iv. investigating, mitigating the consequences of and, to the extent possible, remedying the reported or detected Data Protection Incidents.

5.7 Processing of Personal Data on behalf of the Agency

The Agency shall only assign the responsibility of Processing of Personal Data to a Data Processor if the latter provides adequate warranties of compliance with the level of protection of the Personal Data set forth by this Policy as well as in the applicable procedures, and takes commitments consistent therewith.

6. GOVERNANCE

This Policy establishes, in its Annex, the Agency's Personal Data protection governance based on the roles and responsibilities of the Agency's:

- i. Data Protection Officer;
- ii. Data Protection Supervisory Authority (served by a Registrar); and
- iii. Data Protection Committee.

7. ROLES AND RESPONSIBILITIES

7.1 Data Protection Officer

The Data Protection Officer (including his/her deputy) is responsible for discharging the duties assigned to him/her under Annex to this Policy and to perform any other responsibilities assigned to him/her by the Director General.

7.2 Data Protection Supervisory Authority (Supervisory Authority)

The Supervisory Authority is competent to examine Incidents and review decisions of the Agency in the field of Personal Data Protection, upon a complaint lodged by a Data Subject in accordance with Section 5.4.1 iv. of this Policy and the Rules of Procedure referred to in Annex. The Annex to this Policy details, in particular, its composition and appointment, its duties, its status, and refers also to its Registrar.

7.3 Data Protection Committee

The Data Protection Committee, upon request of the Data Protection Officer, is responsible for providing its inputs, opinions or recommendations in application of the Annex to this Policy.

7.4 Director General

The Director General oversees the implementation of this Policy and decides:

- i. on the appointment or termination of appointment as Data Protection Officer and deputy, as per Section I of the Annex herein;
- ii. on the resources dedicated to the implementation of this Policy;
- iii. on proposals, recommendations or requests made by the Data Protection Officer in the performance of his/her duties, including but not limited in relation with Processing of Sensitive Personal Data, Disclosure of Personal Data outside the Agency, the recognition of the Adequate Level of Protection etc.

7.5 The Department in charge of legal services

The Department in charge of legal services shall advise the Data Protection Officer, the Data Protection Committee, and the Director General for questions on the interpretation and application of the provisions and derived practices of this Policy and more generally on the evolutions of the Agency's Data Protection framework.

7.6 The Department in charge of personnel matters

The Department in charge of personnel matters shall, within its area of responsibility:

- i. implement actions and report to the Data Protection Officer and Director General in the application of this Policy with respect to the Staff Regulations, Rules and Instructions and associated policies concerning Staff Members;
- ii. support the Data Protection Officer when answering Staff Member or other affected Data Subject's questions and complaints concerning the Processing of their Personal Data.

7.7 The Department in charge of the corporate information technology

The Department in charge of corporate information technology shall take the necessary measures in order to:

- i. implement this Policy, advise on and implement the technical solutions to enforce this Policy across the Agency; and
- ii. on privacy and security aspects, mitigate the risks of technologies used by the Agency for the protection of the legitimate interests and rights of Data Subjects.

7.8 The Department in charge of procurement

The Department in charge of procurement shall take the necessary measures in order to implement this Policy, especially through the appropriate provisions to be included in the Agency's procurement tenders, contracts, purchase orders and contracts performed by the Agency for third parties.

7.9 The service in charge of corporate compliance

The service in charge of corporate compliance shall conduct and monitor the implementation of this Policy, with a view to embed it in the management processes of the Agency, without prejudice to the duties and independence of the Data Protection Officer. It shall authorise the publication of implementing documents under this Policy with an ESA-wide scope and maintain an overview of all implementing documentation.

7.10 ESA Security Office

The ESA Security Office shall supervise the correct implementation of the information protection measures specified in the ESA Security Directives, including the protection of Personal Data which has been assigned any of the applicable information protection markings, and necessary technical measures in accordance with the ESA Security Directives. Additionally, with regard to matters that concern compliance with the ESA Security Directives, the ESA Security Office shall investigate security breaches that relate to the protection of information and assist the Data Protection Officer in his/her task to address Personal Data Incidents.

7.11 Directorate Records Officers (DIRO)

The Directorate Records Officers shall ensure that retention periods are assigned to Personal Data records in the Records Retention Schedules.

7.12 ESA Directorates

All ESA Directorates shall appoint Points of Contact for the implementation of this Policy upon request by the DPO.

All Directorate Information Security Officers (ISOs) shall address the protection of Personal Data in their Information Security Management Plan (ISMP), including, but not limited to, the correct assignment of the appropriate protective markings. The Directorate Project/System Security Officers (PSSOs) shall ensure the commensurate protection of Personal Data hosted in the Directorate's systems, in accordance with the assigned level of protection, hence ensuring an adequate mitigation of risk.

7.13 Agency's Staff Members

Each Staff Member has, in the framework of his/her functions, a general duty of:

- i. Care and protection of Personal Data. Each Staff Member shall contribute to the implementation of the principles set forth in this Policy and in particular shall:
 - a. treat any Personal Data with outmost care;
 - b. refrain from any Processing of Personal Data that is not necessary, legitimate and appropriate in the light of his/her professional duties, of this Policy and of its implementing procedures;
 - c. involve the Data Protection Officer, in a timely manner, as required by this Policy or the related procedures and guidelines; and
 - d. whenever involved in a Personal Data Processing, perform, as per modalities recommended by the Personal Data Officer, Personal Data protection impact

assessment to evaluate, in particular, the origin, nature, particularity and severity of the related risks (if any).

- ii. Cooperation. Each Staff Member shall cooperate at all time with the Data Protection Officer, the Supervisory Authority and the Data Protection Committee in their area of responsibility.
- iii. Risk prevention and risk mitigation. Each Staff Member shall identify at his/her level, the risks surrounding Personal Data protection and promptly inform his/her line management and the Data Protection Officer of any circumstances which may result in risks for the Personal Data protection.

7.14 Central Staff Association Committee (CSAC)

The CSAC may provide to the Director General input or recommendation, when and to the extent Staff Members as Data Subjects are concerned, in the following areas:

- a. measures for the proper and effective implementation of this Policy within the Agency; and
- b. amendments to this Policy.

8. ENTRY INTO FORCE AND VALIDITY

This Policy enters into force on the day of its publication and is effective for a period of four (4) years as from the date of its entry into force, unless subject to prior revocation or revision as determined by the DG.

This Policy and its Annex shall be periodically reviewed by the Head of the office in charge of compliance, quality and ethics, to establish whether they require any amendment. Any amendment shall be issued upon decision of the Director General.

9. SUPERSEDED INSTRUCTION

This Instruction supersedes ESA/ADMIN/IPOL-LEGI(2018)01 (“Policy on Personal Data Protection”) which is hereby revoked.

10. PUBLICITY

The present Policy is releasable to the public.

The Director General

ANNEX

GOVERNANCE SCHEME OF THE AGENCY'S PERSONAL DATA PROTECTION

The present Annex forms an integral part of this Policy and establishes, pursuant to Council's Resolution on a "Personal Data Protection Policy", the detailed Personal Data Protection governance of the Agency which is based on the roles and responsibilities of:

- I. The Data Protection Officer;
- II. The Data Protection Supervisory Authority, served by a Registrar; and
- III. The Data Protection Committee.

The implementation of this Policy and of the underlying procedures involve also other stakeholders as identified in this Policy and, more particularly, the ones referred to under its Section 7.

I Data Protection Officer

The Data Protection Officer and his/her deputy shall be Agency's Staff Members.

The deputy Data Protection Officer shall perform, on an exceptional basis and under the same conditions as the Data Protection Officer, the same duties as those of the Data Protection Officer when the latter should be prevented.

Appointment

The Data Protection Officer shall be appointed by the Director General on the basis of professional qualifications in particular expert knowledge of Personal Data protection law and practices and may only be relieved of his/her position of Data Protection Officer by decision of the Director General.

In his/her capacity as Data Protection Officer, the Data Protection Officer has direct access to the Director General, keeping the service in charge of corporate compliance informed.

The contact details of the Data Protection Officer and his/her deputy will be published by means of an Information Note established by the service in charge of corporate compliance.

Duties

The Data Protection Officer and his/her deputy shall:

- i. act as first point of contact concerning Personal Data matters;
- ii. keep and update Personal Data Records, monitor the observance of this Policy and put in place controls and audits;
- iii. examine any matter relating to Personal Data Protection and provide expert opinion in this field (e.g. impact assessments, risk mitigation plans, etc.), without prejudice to the competence of the Supervisory Authority;
- iv. make recommendations to the Director General for:
 - a. the effective implementation and monitoring of this Policy and for audit plans;
 - b. the amendment of this Policy;

- c. the recognition of the Adequate Level of Protection or for the suspension or cancellation of recognition of the Adequate Level of Protection;
- d. any other matter related to the protection of Personal Data; and
- e. report on his/her activities to the Director General, after consultation with the service in charge of corporate compliance;
- v. initiate and deliver Personal Data protection training and generally contribute to Data Protection awareness activities for Agency's Staff Members, in cooperation with the Department in charge of personnel matters;
- vi. following impact assessments to be performed by the relevant organisational entity of the Agency, authorise the Disclosure of Personal Data in the case mentioned in Section 5.3.2 iii. f. above; and
- vii. perform any other duties assigned to him/her by this Policy or by decision of the Director General.

Confidentiality

In the discharge of his/her duties, the Data Protection Officer (and his/her deputy) are bound by an obligation of confidentiality. Such obligation of confidentiality shall continue indefinitely after the termination of their appointment as Data Protection Officer.

Independence

In the discharge of his/her duties as Data Protection Officer, the Data Protection Officer (and his/her deputy) shall act independently and not be subjected to instructions from their hierarchy save that of the Director General provided such instructions do not constitute or amount to constitute a violation of this Policy and that of the principles adopted by Council in its Resolution on "Personal Data Protection Policy".

Consultation

In the performance of his/her duties, the Data Protection Officer (and his/her deputy) may seek for the opinion of, or input from, any organisational stakeholder of the Agency and, via the applicable communication channel, from the Central Staff Association Committee (CSAC).

For the responsibilities set forth in Section I iv. d) he/she may also seek for the opinion of the Data Protection Committee.

For the responsibilities set forth in Section I iv. a), b) and c) he/she shall seek for the opinion of the Data Protection Committee, without prejudice to the duties and independence of the Data Protection Officer.

II Data Protection Supervisory Authority (Supervisory Authority)

An independent Supervisory Authority has been established by Council in order to examine Incidents following decisions of the Agency in the field of Personal Data Protection, upon a complaint lodged by a Data Subject in accordance with Section 5.4.1 iv. of this Policy.

The Supervisory Authority shall be solely and directly accountable towards the Council for carrying out its functions in accordance with this Policy.

The members of the Supervisory Authority (including alternate members) shall perform their responsibilities in accordance with this Policy.

Composition and appointment

The Supervisory Authority shall consist of three members and one alternate member with proven expertise and experience in the field of Personal Data Protection.

The alternate member shall perform the same responsibilities as the members of the Supervisory Authority, if the latter should be prevented.

The members and the alternate member shall not be Staff Members or members of delegations of Members States, Associate Member States or Cooperating States.

The Supervisory Authority shall elect among its members a Chairman and a Deputy Chairman.

The members and the alternate member of the Supervisory Authority shall be nominated by Council for a three-years term, renewable for a maximum of three consecutive terms.

Confidentiality

In the discharge of their duties the members of the Supervisory Authority (and the alternate member) are bound by an obligation of confidentiality in accordance with their Rules of Procedure. Such obligation of confidentiality shall continue indefinitely after the termination of their appointment by Council.

Independence

In the discharge of their duties the members of the Supervisory Authority (and the alternate member) are independent. They shall neither seek nor take instructions from anybody.

Conflict of Interest

The members and the alternate member of the Supervisory Authority shall not take part in a case in which they have a conflict of interest, notably if:

- they have a personal interest in the case;
- they have been previously involved as representative of one of the parties; or
- they participated in preparing the decision which is challenged.

In such case, either party may ask for a change in the composition of the Supervisory Authority.

Rules of Procedure

The Director General establishes the Rules of Procedure for the Supervisory Authority, which shall be approved by Council.

Such Rules of Procedure for the Supervisory Authority are the ones adopted by Council under Annex II of its Resolution on a “Personal Data Protection Policy”.

Decisions

The decisions of the Supervisory Authority are final and shall be binding on all involved parties.

Privileges and Immunities

As external experts, the members of the Supervisory Authority (and the alternate member) shall enjoy the privileges and immunities provided for in Article XVII of Annex I to the ESA Convention.

Expenses

Only mission expenses incurred by the members and the alternate member of the Supervisory Authority in the performance of their duties shall be reimbursed by the Agency and this in accordance with the rules applicable to experts.

Facilities and Seat

The Agency shall provide for all necessary facilities in order to ensure the functioning of the Supervisory Authority.

The Supervisory Authority shall have its official seat at the Headquarters of the Agency; it may meet at other places if necessary.

Registrar

The Council shall appoint a Staff Member to serve as Registrar of the Supervisory Authority.

The Registrar is responsible for matters of current administration of the Supervisory Authority and for all communications and discharge his duties in accordance with the Rules of Procedure set under Annex II of the Council's Resolution on a "Personal Data Protection Policy".

In the discharge of his/her duties, he/she shall be subject to the instructions of the Supervisory Authority.

In the discharge of his/her duties the Registrar shall not be subjected to instructions from his/her hierarchy.

The Registrar shall be afforded the necessary time to perform such duties.

In the discharge of his/her duties the Registrar is bound by an obligation of confidentiality. Such obligation of confidentiality shall continue indefinitely after the termination of his/her appointment by Council.

III. Data Protection Committee

The Director General establishes a Data Protection Committee which shall discharge its duties in accordance with this Policy.

Composition

The Data Protection Committee is composed by:

- a. the representative of the service in charge of corporate compliance who chairs the Committee;
- b. as relevant, by:
 - i. the ESA Records Manager;

- ii. one Agency's Staff Member from each of the following Departments/Services, appointed for this purpose by the Head of the respective Department/Service:
 - Legal services,
 - Personnel matters,
 - Procurement,
 - ESA Security Office,
 - Corporate Information Technology;
- iii. Agency's Staff Members from any ESA Directorate, appointed for this purpose by the relevant Director;
- iv. one member appointed by the Chair of the CSAC.

The above members shall attend and act within their area of responsibility.

Meetings

The Data Protection Committee is convened by its Chair.

Duties

The Data Protection Committee shall, upon request of the Data Protection Officer, provide its input, opinions or recommendations decided in application of the Section I above.

Confidentiality Duties

In the discharge of their duties, the Chair and the members of the Data Protection Committee are bound by an obligation of confidentiality. Such obligation of confidentiality shall continue indefinitely after the termination of their membership.